Ethical Hacking Assignment 1
ITA14 Ethical Hacking ASSIGNMENT 1

Name: C Sangita
REG NO: 192373059
COURSE CODE:ITA1435

.

CO1

CO1: Apply the foundational concepts of ethical hacking, including the types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.

Assignment 1 Title : Design and Develop a Complete Ethical-Hacking Engagement Framework for a University's Authorized Security-Assessment Programme

Scenario — University Authorized Security-Assessment Programme
A university is establishing an Authorized Security-Assessment Programme to test the security of its student portal, learning-management system, email service and campus network before a major upgrade. The programme must cover approximately 20 systems and 50 staff initially, but the framework is expected to remain usable as the programme grows to the whole university and begins to include external, third party assessors.

The management has not yet fixed how ethical-hacking engagements will be governed. Testing may be requested by different departments, carried out by internal staff or external testers, and may touch systems that hold personal data. The team is concerned that an unstructured approach may lead to unauthorized access, legal exposure, damage to live systems, unclear scope or uncoordinated disclosure of discovered vulnerabilities.

You have been appointed as the Ethical-Hacking Governance Team. Your responsibility is not merely to describe hacking tools. You must investigate the requirements, design a complete engagement framework, construct reusable components and documents, integrate the different parts, validate the design through a walkthrough and defend the final framework using evidence.

The final framework must clearly distinguish between what is authorized, what is legal, and what is appropriate for the university. The team is expected to make governance decisions independently and justify why the framework is suitable for the given scenario. No live exploitation is performed; all work stays at the design, documentation and isolated-lab level.

Design Challenge

Create and validate an integrated ethical-hacking engagement framework for the university programme. The framework must define how an engagement is authorized, how scope and rules of engagement are set, how the relevant laws are respected, how different types of attackers are modelled, how discovered vulnerabilities are disclosed responsibly, and how an isolated lab is used where hands-on testing is required.

Your final design must be usable in practice and must demonstrate interaction among the selected components rather than treating each document or rule as an isolated example. Every major governance decision must be supported by evidence and a clear explanation of the trade-offs involved.

Objective:

To design a complete ethical-hacking engagement framework for a university that ensures authorized security testing, legal compliance, ethical practices, threat identification, safe laboratory testing and responsible vulnerability disclosure.

Introduction

Ethical hacking is the authorized process of identifying security weaknesses in computer systems, networks and applications to prevent cyberattacks. It helps organizations identify vulnerabilities before malicious hackers exploit them.

A university uses several digital systems, including student portals, Learning Management Systems (LMS), email services and campus networks. These systems contain important information, including student records, staff details and personal data. Therefore, security assessments must be conducted with proper authorization, legal compliance and ethical responsibilities.

The proposed framework provides a structured method to plan, approve, conduct, document and evaluate security assessments. It also supports future expansion to external security testers and the entire university.

TASK 1 – Formulate the Enquiry and Framework Blueprint 4 Marks • Convert the scenario into a formal set of engagement-governance requirements. Identify the systems in scope, the stakeholders, the expected activities and the constraints.

- Create a framework blueprint showing how authorization, scope, legal compliance, threat modelling, lab testing and disclosure will cooperate in the proposed programme.
- Formulate at least four enquiry questions that your framework must answer, such as who authorizes a test, what is in scope, which laws apply and how findings are disclosed.
- Define at least five design criteria and use them as acceptance criteria for the final framework.

Evidence Expected

A requirements-to-governance blueprint, enquiry questions, design criteria and a clear rationale showing how the proposed framework addresses the scenario.

Solution:

1.1 Requirements Identification

The university requires a security-assessment framework to protect its digital infrastructure.

Requirement	Description
Systems	Student portal, LMS, email and campus network
Initial coverage	Approximately 20 systems
Staff	50 staff members
Stakeholders	Management, IT team, security team and external testers
Testing	Vulnerability identification and security assessment
Authorization	Written approval before every engagement
Legal compliance	Follow applicable cybersecurity and data-protection laws
Disclosure	Report vulnerabilities responsibly
Safety	Avoid damage to live systems and personal data

1.2 Stakeholders

1. University Management – Provides overall approval and funding.
2. IT Administrator – Maintains systems and grants approved access.
3. Ethical Hacking Team – Performs authorized security assessments.
4. Legal Team – Checks legal requirements and agreements.
5. Data Protection Officer (DPO) – Ensures personal data is protected.
6. Department Heads – Request security assessments.
7. External Security Testers – Conduct assessments under written agreements.

1.3 Framework Blueprint

The proposed framework contains six major components:



Framework workflow:

1. Authorization – Obtain written approval from university management.
2. Scope Definition – Identify systems, IP addresses and testing boundaries.
3. Legal Compliance – Verify applicable cybersecurity and privacy laws.
4. Threat Modelling – Identify hacker types, motivations and possible attacks.
5. Lab Testing – Perform practical testing in an isolated environment.
6. Responsible Disclosure – Report vulnerabilities and track remediation.

All six components work together to ensure that security testing is controlled and professional.

1.4 Enquiry Questions

1. Who is responsible for approving an ethical-hacking engagement?
2. Which university systems are included in the testing scope?
3. Which cybersecurity and data-protection laws must be followed?
4. How can different types of hackers and threats be identified?
5. How should discovered vulnerabilities be reported and resolved?

1.5 Design Criteria and Acceptance Criteria

Design criterion	**Acceptance criteria**
Authorization	Every assessment must have written approval.
Scope control	Only approved systems can be tested.
Legal compliance	Applicable laws must be mapped to controls.
Data protection	Personal information must remain confidential.
Safety	Practical testing must use an isolated lab.
Disclosure	Every vulnerability must have a documented report.
Scalability	Framework must support external testers and additional systems.

Rationale: These criteria ensure that the framework is safe, legally compliant, reusable and suitable for future university expansion.

TASK 2 – Design a Hacker Threat Model and Classification 4 Marks • Design a classification of the types of hackers relevant to the university, such as white-hat, black-hat, grey-hat, script kiddie, hacktivist, insider and state-sponsored actors.

• Map each type to its motivation, typical capability and likely targets within the university. • Establish clear criteria and naming so that an actor can be classified consistently. • Demonstrate at least two alternative ways of classifying one borderline actor, then choose and justify the final classification.

Evidence Expected

A documented hacker threat model, classification criteria, a mapping table, rejected alternatives and a justified final classification.

Solution:

2.1 Types of Hackers

Hackers can be classified according to their intentions, motivations, technical abilities and activities.

2.2 Hacker Classification Table

Hacker type	Motivation	Capability	Possible university target
White-hat hacker	Improve security	Advanced	Student portal
Black-hat hacker	Financial gain or damage	Advanced	University database
Grey-hat hacker	Curiosity or recognition	Medium to advanced	Campus network
Script kiddie	Fun or attention	Basic	Email service
Hacktivist	Political or social cause	Medium to advanced	University website
Insider	Personal benefit or revenge	Depends on access	Student records
State-sponsored hacker	Espionage or national interest	Advanced	Research systems

2.3 Classification Criteria

An actor is classified using the following criteria:

1. **Intent:** Whether the actor wants to protect or damage systems.
2. **Authorization:** Whether written permission exists.
3. **Motivation:** Financial, personal, political or security-related.
4. **Technical capability:** Basic, intermediate or advanced.
5. **Target selection:** Whether the actor targets personal data, networks or applications.

2.4 Borderline Actor Classification

Scenario: A security researcher discovers a vulnerability in the university student portal without permission. The researcher does not steal data but reports the vulnerability to the university.

Two possible classifications are:

- **Grey-hat hacker:** Because the researcher tested a system without prior authorization**.**
- **White-hat hacker:** Because the researcher reported the vulnerability to improve security.

Final Classification: Grey-hat hacker

Justification: The researcher initially accessed or tested the system without authorization. Good intentions and later reporting do not automatically make unauthorized testing ethical or lawful. Therefore, grey-hat is the more appropriate classification.

2.5 Threat Model Conclusion

The university must prepare security controls against internal and external threats. It should provide authorized testing opportunities for white-hat hackers and monitor suspicious activities from other hacker categories.

TASK 3 – Create an Ethics and Code-of-Conduct Module 4 Marks • Define the ethical principles

that govern an authorized engagement, such as written authorization, agreed scope, confidentiality, integrity, avoiding harm and honest reporting.

• Design rules or checks that help detect or prevent unethical actions during an engagement. • Construct scenario cases containing acceptable, borderline and unacceptable actions and show how the code of conduct responds to each.

• Explain how the module preserves trust and keeps the engagement lawful and professional.

Evidence Expected

A reusable code-of-conduct module, decision rules, scenario test cases and evidence that the rules separate acceptable from unacceptable actions.

Solution:

3.1 Ethical Principles

The ethical-hacking team must follow the following principles during every security assessment.

1. **Written Authorization:** Testing must begin only after receiving written permission.
2. **Scope Limitation:** Testers must access only approved systems.
3. **Confidentiality:** Student and staff information must not be shared with unauthorized persons.
4. **Integrity:** Testers must not modify or destroy university information.
5. **Avoiding Harm:** Testing must not interrupt university services.
6. **Honest Reporting:** All discovered vulnerabilities must be reported accurately.
7. **Responsible Disclosure:** Vulnerabilities must be communicated privately to the responsible team.
8. **Accountability:** Every testing activity must be recorded.

3.2 Code-of-Conduct Rules

Rule	Description
Rule 1	Verify authorization before testing.
Rule 2	Follow approved testing dates and times.
Rule 3	Do not access personal information unnecessarily.
Rule 4	Do not install unauthorized software.
Rule 5	Do not delete or modify university data.
Rule 6	Stop testing immediately if a system becomes unstable.
Rule 7	Report critical vulnerabilities immediately.
Rule 8	Maintain confidential testing records.

3.3 Decision Rules

The following rules determine whether an action is ethical.

- If written authorization exists and the activity is within scope, testing is permitted.
- If the activity is outside the approved scope, testing must stop until additional approval is obtained.
- If personal information is exposed, access must stop and the incident must be reported.
- If testing affects system availability, testing must stop immediately.
- If a vulnerability is discovered, it must be documented and reported privately.

3.4 Ethical Scenario Test Cases

Scenario	Action	Classification
Testing an approved student portal	Conducting an approved vulnerability assessment	Acceptable
Finding personal data accidentally	Stopping access and reporting the incident	Acceptable
Testing an unapproved email server	Accessing it without permission	Unacceptable
Downloading student records for proof	Collecting unnecessary personal data	Unacceptable
Requesting additional approval	Waiting before testing a new system	Acceptable
Continuing testing after a service outage	Ignoring the warning	Unacceptable

3.5 Importance of the Ethics Module

The ethics module ensures that testers act professionally and responsibly. It protects university information, prevents unauthorized access and maintains trust between the university and security assessment team.

TASK 4 – Construct a Legal-Compliance Mapping 4 Marks • Map the engagement to the relevant provisions of the Information Technology Act, 2000 on unauthorized access and data, and compare them with an international law such as the Computer Fraud and Abuse Act.
• Build a table of offences, obligations and penalties related to unauthorized access and data protection. • Connect each legal requirement to a specific control in the engagement framework. • Decide and justify which legal requirements apply when a test touches systems that hold personal data.

Evidence Expected

A legal-compliance mapping, an offences-and-penalties table, the controls linked to each requirement and a justified conclusion on which laws apply.

Solution:

4.1 Indian Legal Framework

The primary legislation applicable to the university's cybersecurity assessment is the Information Technology Act, 2000.

It provides legal provisions concerning unauthorized access, computer-related offences, identity theft, privacy violations and disclosure of confidential information.

4.2 Relevant Legal Provisions

Section	Offence / Requirement	Penalty or consequence
IT Act Section 43	Unauthorized access, downloading or damaging computer resources	Compensation to affected persons
Section 66	Dishonest or fraudulent computer-related acts covered under Section 43	Imprisonment up to 3 years, fine up to ₹5 lakh, or both
Section 66C	Identity theft and misuse of passwords or electronic signatures	Imprisonment up to 3 years and fine up to ₹1 lakh
Section 66D	Cheating by personation using computer resources	Imprisonment up to 3 years and fine up to ₹1 lakh
Section 66E	Violation of privacy	Imprisonment up to 3 years, fine up to ₹2 lakh, or both
Section 72	Unauthorized disclosure of information obtained under powers provided by the Act	Imprisonment up to 2 years, fine up to ₹1 lakh, or both
Section 72A	Disclosure of information in breach of lawful contract	Imprisonment up to 3 years, fine up to ₹5 lakh, or both

These provisions demonstrate why authorization, confidentiality and data protection are essential.

India Code+2

4.3 International Law – Computer Fraud and Abuse Act (CFAA)

The Computer Fraud and Abuse Act (CFAA) is a United States federal law under 18 U.S.C. Section 1030.

It addresses activities such as:

1. Unauthorized access to protected computers.
2. Obtaining information without authorization.
3. Causing damage to computer systems.
4. Computer-related fraud.
5. Unauthorized password trafficking.

Depending on the offence and circumstances, penalties can include fines and imprisonment. Certain offences carry imprisonment of up to 10 years or more.

US Code+1

4.4 Comparison of Indian IT Act and US CFAA

Basis	Indian IT Act, 2000	US CFAA
Country	India	United States
Main purpose	Cybersecurity and electronic transactions	Prevent computer fraud and unauthorized access
Unauthorized access	Section 43	Section 1030
Computer damage	Sections 43 and 66	Section 1030(a)(5)
Identity misuse	Section 66C	Covered under applicable CFAA provisions where relevant
Enforcement	Indian legal authorities	US federal authorities

4.5 Legal Compliance Controls

Legal requirement	Framework control
Prevent unauthorized access	Written authorization form
Protect personal information	Data minimization and confidentiality
Prevent identity misuse	Restricted test accounts
Prevent system damage	Isolated lab and testing limits
Prevent information disclosure	Encrypted vulnerability reports
Maintain accountability	Engagement logs and audit records

4.6 Data Protection Requirements

When an assessment involves personal data, the university must also consider the Digital Personal Data Protection Act, 2023 (DPDP Act) and applicable rules and commencement notifications.

Important requirements include:

- Protect personal data from unauthorized access.
- Use personal data only for an authorized and specified purpose.
- Restrict access to authorized personnel.
- Apply appropriate security safeguards.
- Follow applicable personal-data breach notification requirements.
- Retain and erase personal data according to applicable legal requirements.

4.7 Final Legal Decision

Since the university operates in India, the Indian IT Act and applicable Indian data-protection requirements are the primary legal framework. The CFAA becomes relevant when an engagement involves computers or conduct within its jurisdiction, such as certain US-based third-party systems.

Written authorization alone does not automatically make every testing action lawful. Testing must also respect privacy, contractual restrictions, third-party ownership and applicable legal requirements.

TASK 5 – Create a Scope and Rules-of-Engagement Document 4 Marks • Design a scope and rules-of-engagement (RoE) document that defines in-scope and out-of-scope systems, testing windows, permitted and prohibited techniques and escalation paths. • Create rules for recording and verifying the written authorization behind each engagement. • Establish clear naming and boundaries so that an out-of-scope request can be detected. • Construct at least one transformation of the RoE into a pre-engagement checklist.

Evidence Expected

A complete RoE document, authorization-verification rules, scope boundaries and a derived pre engagement checklist.

Solution:

5.1 Rules of Engagement (RoE)

Rules of Engagement define the conditions under which ethical hacking is conducted.

Engagement Name: University Security Assessment Programme
Purpose: To identify security vulnerabilities in university systems before a major technology upgrade.

5.2 Scope Definition

In-scope systems	Out-of-scope systems
Student portal	External bank servers
Learning Management System	Third-party payment gateways
University email service	Personal devices
Campus network	External government systems
Approved test servers	Unapproved cloud services

5.3 Testing Schedule

Activity	Schedule
Authorization	Before testing
Scope verification	Before testing
Lab testing	Approved testing period
Vulnerability reporting	Immediately after discovery
Remediation	Within the agreed timeline
Retesting	After fixes are completed

5.4 Permitted Techniques

1. Network discovery within the approved lab.
2. Vulnerability scanning.
3. Configuration assessment.
4. Password-policy review using approved test accounts.
5. Web application security assessment.
6. Security log analysis.

5.5 Prohibited Techniques

1. Testing systems without authorization.
2. Denial-of-service attacks against live systems.
3. Deleting or modifying university records.
4. Stealing passwords or personal information.
5. Installing malware.
6. Attacking third-party systems without permission.
7. Social engineering without specific written approval.

5.6 Authorization Verification Rules

Before testing begins, the team must verify:

- Engagement ID.
- Name of the approving authority.
- Written approval date.

- Approved systems and IP addresses.
- Testing start and end dates.
- Permitted activities.
- Emergency contact details.
- Tester identity.

Every engagement receives a unique identification number.

Example: UNI-SEC-2026-001

An out-of-scope system must be rejected even if it is technically accessible.

5.7 Escalation Process

1. Tester identifies an unexpected issue.
2. Tester stops the affected activity.
3. Tester informs the security team leader.
4. Security team leader contacts the IT administrator.
5. Serious incidents are reported to university management.
6. Testing resumes only after the issue is resolved and approval is confirmed.

5.8 Pre-Engagement Checklist

This checklist is created from the RoE document.

Checklist item	**Status**
Written authorization received	Yes / No
Scope approved	Yes / No
Tester identity verified	Yes / No
Testing dates confirmed	Yes / No
Legal requirements reviewed	Yes / No
Backup availability confirmed	Yes / No
Emergency contacts recorded	Yes / No
Lab configuration verified	Yes / No
Disclosure contact assigned	Yes / No

Conclusion: The RoE document prevents unauthorized activities and ensures that every assessment follows clearly defined boundaries.

TASK 6 – Build an Authorization and Disclosure Layer 5 Marks • Create an authorization workflow covering the request, approval, written sign-off and recording of each engagement.

• Design a responsible (coordinated) disclosure process with a reporting format, remediation window and timeline, and compare it with full disclosure and bug-bounty approaches.

• Develop operations for logging approvals and status updates and for deciding when disclosure may proceed.

• Create rules for choosing between coordinated and full disclosure for a given finding. • Demonstrate that this layer interacts correctly with the rules-of-engagement and legal-compliance components.

Evidence Expected

An authorization workflow, a responsible-disclosure process, logging and decision operations, disclosure rules and evidence of interaction with the other components.

Solution:

6.1 Authorization Workflow

The authorization layer ensures that every security assessment is formally approved and recorded.



Workflow:

1. Request Submission – Department submits a security assessment request.
2. Initial Review – Security team checks the purpose and requirements.
3. Scope Approval – IT team confirms the systems to be tested.
4. Legal Review – Legal team verifies applicable laws and agreements.
5. Management Approval – Authorized management approves the engagement.
6. Written Sign-off – Both university and tester sign the authorization document.
7. Registration – Engagement ID is generated and approval is logged.
8. Testing – Assessment begins according to the approved RoE.

6.2 Authorization Record

Field	Example
Engagement ID	UNI-SEC-2026-001
Department	Computer Science
Target	Student Portal

Tester	Authorized Security Team
Approval authority	IT Director
Start date	10-11-2026
End date	15-11-2026
Status	Approved

6.3 Responsible Disclosure Process

Responsible disclosure is the process of privately reporting discovered security vulnerabilities to the system owner and allowing sufficient time for remediation before public disclosure.

Disclosure Steps:

1. Identify the vulnerability.
2. Record the affected system and evidence.
3. Prepare a vulnerability report.
4. Send the report securely to the university security team.
5. Acknowledge the report within 2 working days.
6. Classify the vulnerability according to severity.
7. Provide a remediation window.
8. Verify the correction through retesting.
9. Close the finding after successful verification.

6.4 Proposed Disclosure Timeline

Activity	**Timeline**
Initial report	Within 24 hours of discovery
Acknowledgement	Within 2 working days
Critical vulnerability remediation target	7 days
High vulnerability remediation target	15 days
Medium vulnerability remediation target	30 days
Low vulnerability remediation target	60 days
Retesting	After remediation
Public disclosure	Only after coordinated review and approval

These are proposed internal service targets, not statutory deadlines. Active exploitation or a personal-data breach requires immediate escalation and applicable legal reporting procedures.

6.5 Comparison of Disclosure Approaches

Approach	**Description**	**Advantages**	**Disadvantages**
Coordinated disclosure	Researcher informs the owner privately and coordinates remediation	Protects users and allows fixing	Requires cooperation
Full disclosure	Vulnerability details are published publicly	Creates public awareness	Attackers may exploit before a fix
Bug bounty	Researchers report vulnerabilities under a defined reward	Encourages security research	Requires budget and clear programme rules

	programme		

Selected approach: Coordinated vulnerability disclosure.

Reason: It is suitable for a university because it protects student information and gives the IT team time to correct vulnerabilities before public disclosure.

6.6 Disclosure Decision Rules

- Critical vulnerabilities must be reported immediately.
- Vulnerabilities involving personal data must be escalated to the security and data-protection teams.
- Public disclosure must not reveal student records, credentials or confidential information.
- If the university does not respond, the security governance team must escalate the matter to management.
- Full disclosure is considered only after legal review, risk assessment and an approved communication decision.

6.7 Integration with Other Components

Component	**Interaction**
Authorization	Confirms permission before testing
RoE	Defines approved targets and techniques
Legal compliance	Ensures reports protect personal information
Lab testing	Provides a safe testing environment
Document library	Stores authorization and vulnerability reports

Conclusion: The authorization and disclosure layer provides accountability and ensures vulnerabilities are resolved without unnecessary exposure of university systems.

TASK 7 – Design an Isolated Ethical-Hacking Lab 5 Marks • Design a safe, isolated lab using a Kali Linux machine and one or more authorized target machines on a host-only network with reserved addresses such as 192.168.56.0/24.

• Specify the components, roles and connectivity of the lab and the steps used to record its configuration.

• Develop at least two operations, such as verifying connectivity between the machines and recording the lab setup.

• Construct a small comparison between a host-only and a NAT lab network and justify the chosen design.

• Explain how the lab keeps all testing authorized and contained within the isolated environment.

Evidence Expected

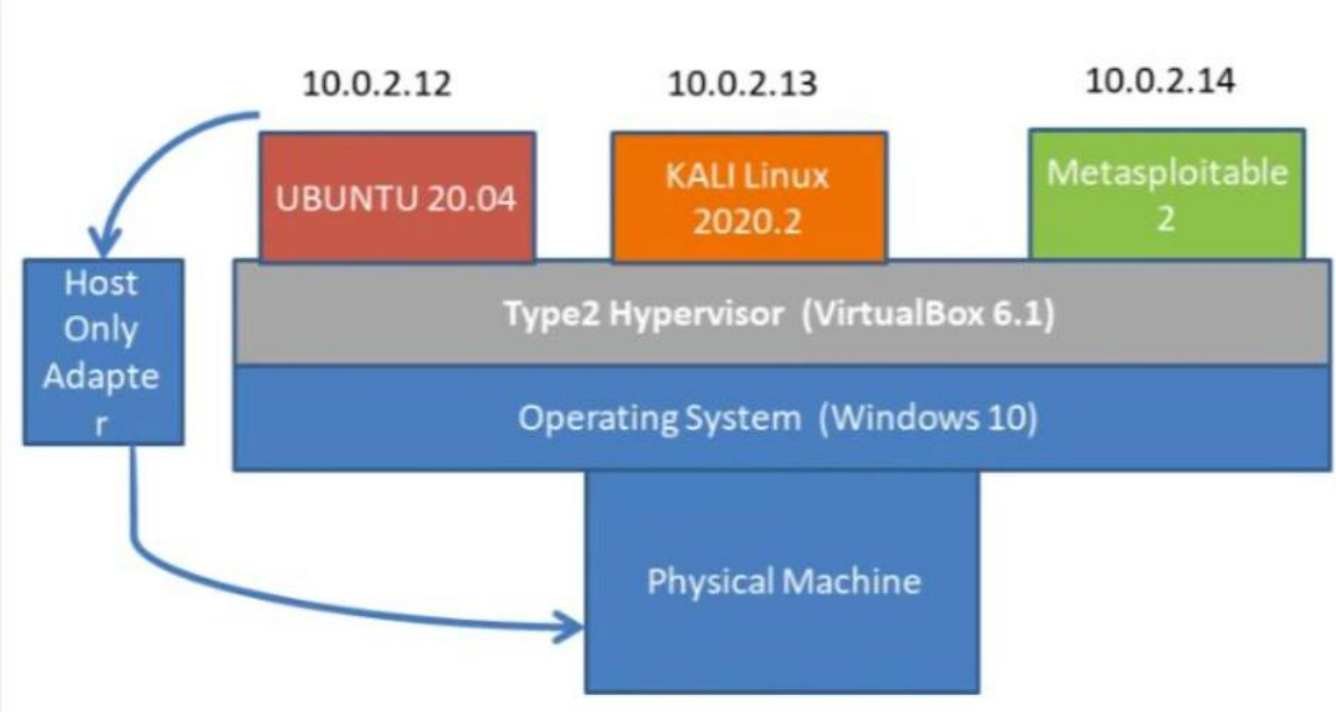
An isolated-lab design, a component and connectivity specification, verification operations, a comparison of network options and a justified final lab model.

Solution:

7.1 Lab Environment

An isolated ethical-hacking lab is a controlled environment used to perform practical security assessments without affecting real university systems.

The proposed lab uses Kali Linux and an authorized target machine connected through a host-only network.



7.2 Lab Components

Component	Purpose
Host computer	Runs VirtualBox
Kali Linux VM	Security testing machine
Target VM	Authorized vulnerable test machine
VirtualBox	Virtualization software
Host-only network	Provides isolated communication
Lab documentation	Stores configuration and test records

7.3 Network Configuration

Machine	IP Address	Role
Kali Linux	192.168.56.10	Testing machine
Target machine	192.168.56.20	Authorized target
Host-only network	192.168.56.0/24	Isolated network

Both virtual machines must use the same host-only network adapter.

Internet access should be disabled during testing unless a separately approved update procedure is required.

7.4 Lab Setup Procedure

1. Install Oracle VirtualBox.

2. Create a Kali Linux virtual machine.
3. Create an authorized target virtual machine.
4. Open VirtualBox Network Settings.
5. Select Host-only Adapter for both machines.
6. Configure the IP addresses.
7. Start both virtual machines.
8. Verify network connectivity.
9. Record the configuration and take screenshots.
10. Create snapshots before testing.

7.5 Operation 1 – Verify Connectivity

From Kali Linux, execute:

ip addr

This command displays the network interface and assigned IP address.

Next, verify the target machine connection:

ping -c 4 192.168.56.20

Expected output:

PING 192.168.56.20
64 bytes from 192.168.56.20
64 bytes from 192.168.56.20
64 bytes from 192.168.56.20
64 bytes from 192.168.56.20
4 packets transmitted
4 received
0% packet loss

This confirms that the two lab machines can communicate.

7.6 Operation 2 – Record Lab Configuration

Execute the following commands:

hostname
ip addr
ip route

Save the output:

mkdir -p ~/ethical-lab
{
echo "ETHICAL HACKING LAB CONFIGURATION"
date
hostname
ip addr
ip route
} > ~/ethical-lab/lab-config.txt

The file lab-config.txt stores the lab configuration for documentation and verification.

7.7 Host-only vs NAT Network Comparison

Feature	Host-only Network	NAT Network
Internet access	Normally unavailable	Available through NAT
VM communication	Yes	Yes, depending on configuration
Isolation	Strong isolation from external network	Provides outbound connectivity
External access	Not normally available	Outbound access available
Security testing	Suitable for isolated lab	Suitable for controlled internet access

7.8 Selected Lab Model

Host-only network is selected.

Reasons:

1. Prevents direct exposure of the target machine to the internet.
2. Allows communication between Kali Linux and the target VM.
3. Reduces the risk of accidental testing against external systems.
4. Provides a controlled environment.
5. Supports repeatable practical experiments.

7.9 Lab Safety Rules

- Only authorized target machines can be used.
- Never connect an intentionally vulnerable target to a public network.
- Use snapshots before every experiment.
- Do not store real student or staff information in the lab.
- Stop testing if unexpected network connections occur.
- Record all testing activities.

Conclusion: The isolated lab provides a safe and controlled environment for practicing ethical-hacking techniques without affecting university infrastructure.

TASK 8 – Develop a Reusable Document Library 4 Marks • Create a minimum of four reusable engagement documents supporting the framework, including at least one authorization form and one finding report.

• Use sensible default fields where appropriate and explicitly design the content of each document. • At least one document, such as the finding report, must produce a structured output that integrates with another component of the framework.

• Create test entries that demonstrate valid, boundary and invalid inputs and document the expected result.

Evidence Expected

A reusable document library, documented fields, a structured report output, test entries and evidence of integration with the framework.

Solution:

8.1 Introduction

A document library contains reusable forms and reports required for managing ethical-hacking engagements. It ensures consistency, accountability and proper record maintenance.

The university will maintain the following four documents.

8.2 Document 1 – Authorization Form

Purpose: To obtain official permission before starting an assessment.

Field	Description
Engagement ID	Unique assessment number
Department	Requesting department
System name	Target system
IP address	Approved target address
Tester name	Authorized tester
Testing period	Start and end date
Approval authority	Management or IT Director
Signature	Written approval
Status	Pending / Approved / Rejected

8.3 Document 2 – Scope and Rules-of-Engagement Form

Purpose: To define testing boundaries and permitted activities.

Fields:

1. Engagement ID
2. In-scope systems
3. Out-of-scope systems
4. Approved testing methods
5. Prohibited activities
6. Testing schedule
7. Emergency contact
8. Escalation procedure
9. Tester acknowledgement

8.4 Document 3 – Vulnerability Finding Report

Purpose: To record and communicate discovered vulnerabilities.

Field	Description
Finding ID	Unique vulnerability number
Engagement ID	Related assessment
Vulnerability title	Name of the weakness

Affected system	Target system
Severity	Critical / High / Medium / Low
Description	Details of vulnerability
Evidence	Safe proof or screenshot
Impact	Possible security consequences
Recommendation	Suggested solution
Status	Open / In Progress / Fixed / Closed
Retest result	Passed / Failed

Structured Report Example:


```
{
 "finding_id": "VUL-001",
 "engagement_id": "UNI-SEC-2026-001",
 "system": "Student Portal",
 "vulnerability": "Weak Password Policy",
 "severity": "Medium",
 "impact": "Increased risk of account compromise",
 "recommendation": "Implement strong password requirements and MFA",
 "status": "Open",
 "retest": "Pending"
}
```


This structured report is connected to the disclosure module. The finding ID and engagement ID help the university track the vulnerability from discovery to closure.

8.5 Document 4 – Final Assessment Report

Purpose: To provide a summary of the completed security assessment.

Fields:

1. Engagement ID
2. Assessment date
3. Systems tested
4. Testing team details
5. Number of vulnerabilities discovered
6. Critical findings
7. High findings
8. Medium findings
9. Low findings
10. Remediation recommendations
11. Retesting results
12. Final approval

8.6 Document Validation Test Cases

Test input	Expected result	Status

Valid engagement ID and approved system	Accept form	Valid
Missing tester signature	Reject form	Invalid
Out-of-scope system	Reject assessment	Invalid
Medium-severity finding with complete details	Accept report	Valid
Missing finding ID	Reject report	Invalid
Missing remediation status	Mark report incomplete	Boundary

8.7 Document Library Integration

The four documents work together as follows:

1. Authorization form confirms permission.
2. RoE form defines testing boundaries.
3. Finding report records security weaknesses.
4. Final assessment report summarizes results.

Conclusion: The reusable document library improves documentation, reduces errors and provides evidence for security audits.

TASK 9 – Integrate, Test and Refine the Framework 4 Marks • Integrate the components created in Tasks 2-8 into one coherent engagement framework. • Construct a realistic walkthrough of an authorized assessment from request and authorization, through testing in the isolated lab, to responsible disclosure.

• Design systematic test cases covering missing authorization, out-of-scope requests, legal conflicts and delayed disclosure.

• Record the problems encountered during the walkthrough and show how the framework was refined to address them.

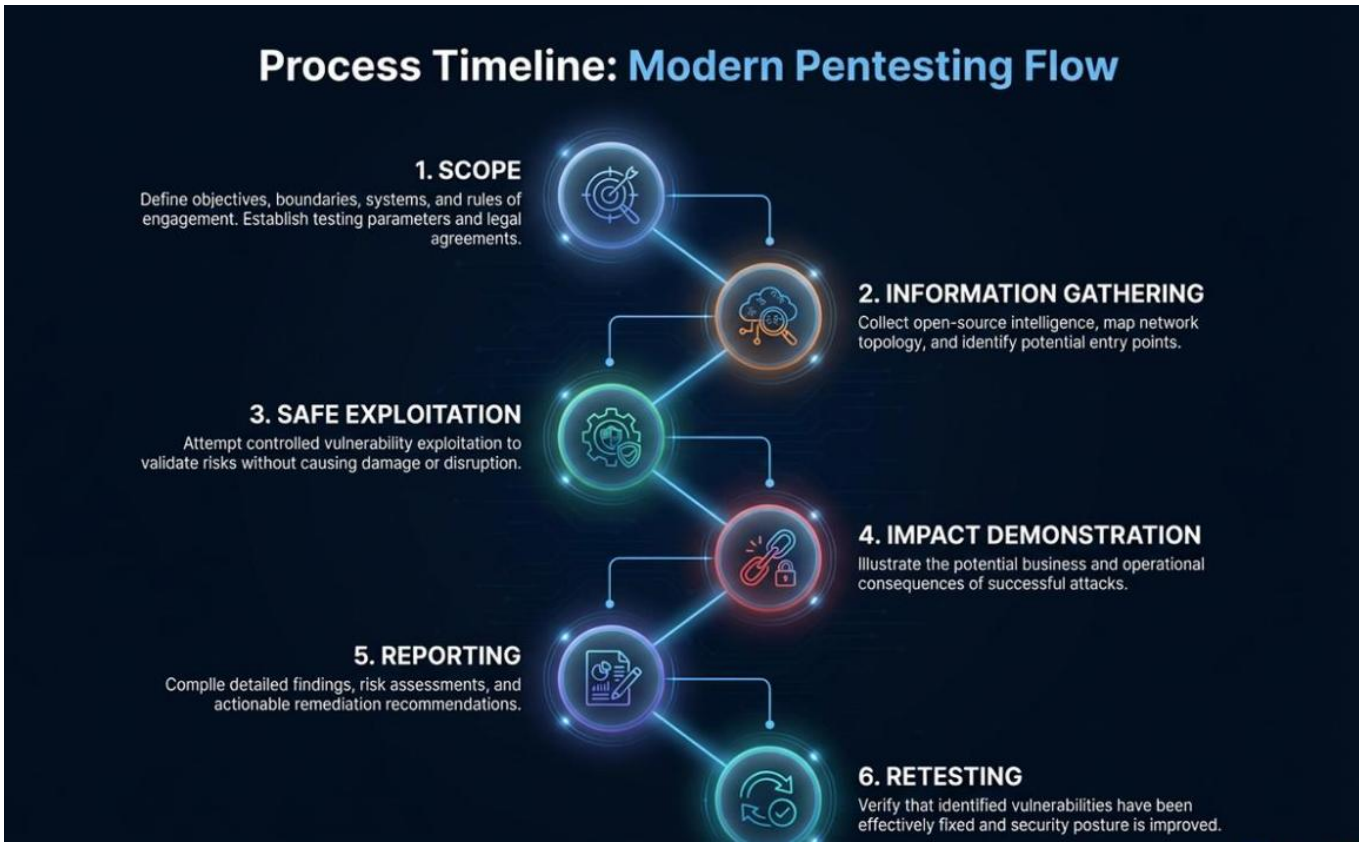
Evidence Expected

A reproducible integrated framework, a workflow walkthrough, systematic test cases, refinement evidence and a final corrected framework.

Solution:

9.1 Framework Integration

The components developed in Tasks 2–8 are integrated into one complete ethical-hacking process.



- Department submits an assessment request.
- Authorization team verifies written permission.
- IT team approves the scope and RoE.
- Legal team checks compliance requirements.
- Threat model identifies possible security risks.
- Testing is conducted in the isolated lab.
- Vulnerabilities are documented.
- Findings are sent through responsible disclosure.
- IT team fixes identified vulnerabilities.
- Security team performs retesting.
- Final assessment report is submitted.

9.2 Realistic Walkthrough

Scenario: The university wants to assess the security of its student portal before a major upgrade.

Stage	Activity	Expected result
1	Computer Science department submits request	Request registered
2	Management provides written approval	Authorization completed
3	IT team defines the scope	Student portal approved
4	Legal team reviews requirements	Legal compliance confirmed
5	Security team prepares threat model	Threats identified
6	Kali Linux and target VM are configured	Isolated lab ready
7	Authorized testing is conducted	Security weaknesses identified
8	Finding report is generated	Vulnerabilities documented

9	Report is submitted privately	Disclosure initiated
10	IT team applies security fixes	Vulnerabilities corrected
11	Security team retests the system	Fixes verified
12	Final report is submitted	Engagement closed

9.3 Systematic Test Cases

Test case	Input or situation	Expected result
TC01	Testing without written authorization	Testing blocked
TC02	Request to test an unapproved server	Request rejected
TC03	Personal data encountered during testing	Stop access and escalate
TC04	Critical vulnerability discovered	Immediate notification
TC05	Disclosure delayed beyond target date	Escalation to management
TC06	System becomes unstable	Stop testing
TC07	Valid authorization and approved scope	Testing permitted

9.4 Problems Identified During Walkthrough

Problem	Solution / Refinement
Missing authorization details	Introduced mandatory authorization fields
Confusion about system boundaries	Added an approved IP and system list
Risk of exposing personal data	Introduced data minimization
Delayed vulnerability reporting	Added disclosure timelines
Missing testing records	Introduced engagement logs
External tester access risk	Added identity verification and contracts

9.5 Final Refined Framework

After testing the workflow, the following improvements were introduced:

1. Every engagement receives a unique ID.
2. Testing cannot begin without written approval.
3. All targets must be listed in the RoE.
4. Personal data must be protected.
5. Findings must be reported within defined timelines.
6. All approvals and status changes must be logged.
7. Testing activities must be reproducible in an isolated lab.

Conclusion: Integration testing confirms that all components work together and that the framework can handle common authorization, scope and disclosure problems.

TASK 10 – Create a Scalability and Governance Evaluation 4 Marks • Construct scenarios representing a small programme (one department) and a large programme (the whole university with external assessors), with the number of systems and testers involved. • Experiment with at least three important processes from the framework and record meaningful measures such as approval turnaround,

scope coverage or the number of steps.

• Create a comparison table and at least one suitable chart or structured visualization. • Use the evidence to refine the governance of the framework rather than simply reporting the measures.

Evidence Expected

A reproducible evaluation setup, a comparison table, a visualization, an interpretation and evidence of at least one governance refinement based on the results.

Solution:

10.1 Introduction

The scalability evaluation checks whether the proposed framework can support both a small departmental security programme and a large university-wide assessment programme.

Two scenarios are considered.

10.2 Programme Scenarios

Parameter	Small Programme	Large Programme
Departments	1	10
Systems	5	100
Testers	2	20
External assessors	0	5
Engagements	2	15
Approval authority	Department Head and IT	Central Governance Team
Documentation	Basic	Centralized digital library

Note: These are proposed evaluation scenarios, not actual university measurements.

10.3 Process Evaluation

Three important processes are evaluated.

1. Authorization approval.
2. Scope verification.
3. Vulnerability reporting and disclosure.

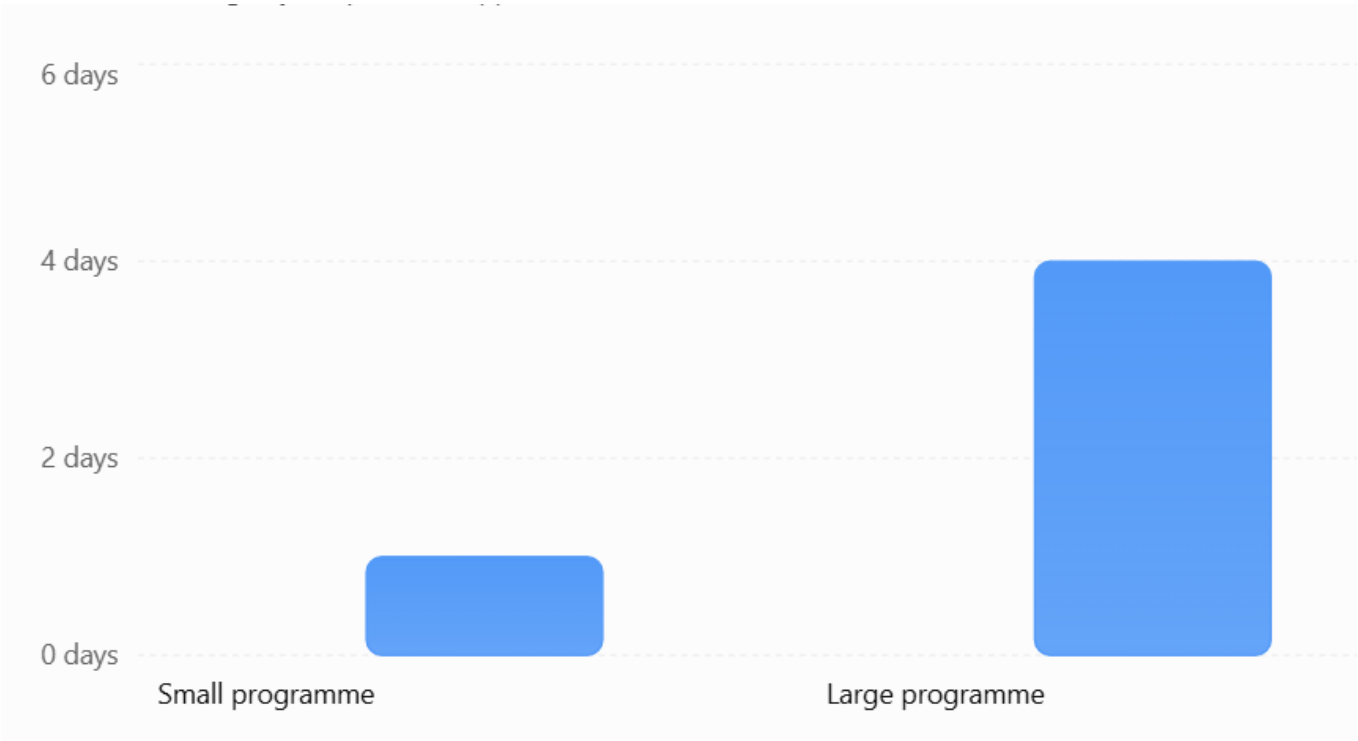
The following values are illustrative planning estimates.

Process	Small Programme	Large Programme
Approval turnaround	1 working day	4 working days
Scope verification	2 steps	5 steps
Finding documentation	10 minutes	15 minutes
Approval checkpoints	2	4
Reporting system	Individual reports	Centralized reporting

10.4 Visualization – Approval Turnaround

Approval Turnaround Comparison

Illustrative working days required for approval.



10.5 Interpretation

The evaluation shows that:

1. Small programmes require fewer approval steps.
2. Large programmes need centralized governance.
3. External assessors require additional identity and contract verification.
4. More systems increase the complexity of scope management.
5. Centralized vulnerability reporting helps track findings across departments.

10.6 Governance Improvements

Based on the evaluation, the following changes are introduced:

- Establish a central security governance team.
- Use standardized digital authorization forms.
- Assign unique engagement IDs.
- Maintain a centralized system inventory.
- Introduce role-based access for internal and external testers.
- Automate reminders for pending approvals and vulnerability fixes.
- Conduct periodic reviews of external assessors.

10.7 Scalability Conclusion

The proposed framework is suitable for both small and large programmes because it uses reusable documents, centralized records and standardized approval procedures. It can be expanded to cover the entire university without changing its basic governance structure.

TASK 11 – Defend the Framework Under a Changed Requirement 4 Marks • Changed requirement: the university now runs continuous and third-party assessments with stricter data-protection rules and a shorter disclosure timeline, and needs the framework to remain easy to govern and extend.
• Create a revised version of your framework by deciding which components should be retained, modified, replaced or redesigned.
• Construct at least one new or modified component that directly addresses the changed requirement and show how it integrates with the existing framework.
• Defend the final framework using evidence from your walkthrough, scalability evaluation, legal mapping and disclosure process.
• Identify at least two trade-offs or limitations that remain in your final design and propose future improvements.

Evidence Expected
A revised framework, demonstrated adaptation, an evidence-based defence, explicit trade-offs and a clear explanation of how the final design satisfies the changed requirements.

Solution:

11.1 Changed Requirement

The university introduces a new requirement:

- Continuous security assessments.
- Increased use of third-party security testers.
- Stricter personal-data protection.
- Shorter vulnerability disclosure timelines.
- Easy expansion and centralized governance.

The existing framework must be modified to support these requirements.

11.2 Revised Framework

Component	Decision	Modification
Authorization	Modify	Introduce recurring approvals with defined expiry and renewal
Scope and RoE	Modify	Add continuous testing windows and third-party boundaries
Legal compliance	Retain and strengthen	Add stricter data-protection checks
Threat modelling	Retain	Include external and insider threats
Ethics module	Retain	Add third-party confidentiality requirements
Isolated lab	Modify	Add more target environments and snapshots
Disclosure module	Redesign	Introduce shorter reporting and escalation timelines
Document library	Modify	Add third-party agreements and data-handling records
Governance	Redesign	Introduce centralized continuous monitoring and review

11.3 New Component – Continuous Assessment Governance Module

This module manages recurring security assessments and external testers.

Main functions:

1. Maintain a centralized inventory of university systems.
2. Schedule recurring security assessments.
3. Verify third-party tester identities.
4. Check signed contracts and confidentiality agreements.
5. Monitor assessment activities.
6. Track vulnerabilities continuously.
7. Send automatic remediation reminders.
8. Escalate critical findings immediately.

11.4 Revised Disclosure Timeline

Activity	Revised target
Critical finding notification	Within 1 hour
High finding notification	Within 4 hours
Medium finding notification	Within 1 working day
Low finding notification	Within 2 working days
Critical issue escalation	Immediately
Remediation tracking	Continuous
Retesting	After every approved fix

These are proposed programme targets. Legal breach notifications must follow the applicable statutory requirements and cannot be replaced by these internal timelines.

11.5 Integration with Existing Framework

The new continuous assessment module connects with:

- Authorization module – Verifies recurring approvals.
- RoE module – Checks approved targets and testing windows.
- Legal module – Enforces personal-data protection.
- Lab module – Supports safe practical testing.
- Disclosure module – Tracks vulnerability notifications.
- Document library – Stores all assessment records.

11.6 Evidence Supporting the Final Framework

Evidence	Result	Support for the framework
Authorization walkthrough	Testing blocked without approval	Prevents unauthorized access
Scope testing	Out-of-scope targets rejected	Protects third-party systems
Legal mapping	Controls linked to applicable laws	Supports legal compliance
Lab verification	Isolated connectivity confirmed	Reduces testing risks
Scalability evaluation	Centralized governance required for expansion	Supports university-wide use
Disclosure evaluation	Escalation needed for delayed reports	Improves vulnerability

		management

11.7 Trade-offs and Limitations

Trade-off 1 – Security vs Convenience

Strict authorization and approval procedures improve security but may delay assessments.

Improvement: Introduce standardized digital forms and predefined approval workflows.

Trade-off 2 – Continuous Testing vs System Availability

Continuous testing improves vulnerability detection but may affect live university services.

Improvement: Use isolated environments, approved testing windows and controlled non-disruptive assessments.

Trade-off 3 – Third-Party Access vs Data Confidentiality

External testers provide specialized skills but increase the risk of data exposure.

Improvement: Use confidentiality agreements, least-privilege access and monitored test accounts.

Trade-off 4 – Short Disclosure Timeline vs Remediation Quality

Shorter timelines improve response speed but may create pressure on IT teams.

Improvement: Introduce severity-based escalation and assign dedicated remediation teams**.**

11.8 Final Defence

The proposed ethical-hacking engagement framework is suitable for the university because it provides a complete governance structure for planning, approving, performing and evaluating security assessments.

It combines written authorization, clear scope boundaries, ethical principles, legal compliance, threat classification, isolated lab testing and responsible vulnerability disclosure.

The walkthrough demonstrates that unauthorized testing can be blocked, the isolated lab provides a controlled testing environment, and vulnerability reports can be tracked until remediation.

The scalability evaluation demonstrates how centralized governance and reusable documents support expansion from a small departmental programme to university-wide assessments involving external testers.

The revised framework also addresses continuous assessments, stricter data protection and shorter disclosure timelines.

Therefore, the framework provides a secure, ethical, legally aware, reusable and scalable solution for the university's Authorized Security-Assessment Programme.

Final Result:

A complete ethical-hacking engagement framework was designed for the university. It includes hacker classification, ethical principles, legal compliance, scope management, authorization, responsible disclosure, isolated laboratory design, reusable documents, integration testing, scalability evaluation and future governance improvements. The framework ensures that security assessments are authorized, controlled, safe and professionally managed.

MARK DISTRIBUTION

Task	Marks
TASK 1 – Formulate	4
TASK 2 – Design	4
TASK 3 – Create	4
TASK 4 – Construct	4
TASK 5 – Create	4
TASK 6 – Build	5
TASK 7 – Design	5

TASK 8 – Develop	4
TASK 9 – Integrate,	4
TASK 10 – Create	4
TASK 11 – Defend	4
TOTAL	50